

Cheatsheet de normas y documentos técnicos

Cómo leer el nombre de una norma

ISO/IEC 27035-1:2023

Parte	Significado
ISO	Publicada solo por ISO.
ISO/IEC	Publicada junto con IEC; es lo habitual en tecnologías de la información.
27035	Número de la norma. La serie 27000 agrupa las normas de seguridad de la información.
-1	Parte de una norma dividida en varios documentos.
:2023	Año de la edición. Una edición nueva reemplaza a la anterior.
ISO/TS	Especificación técnica: documento de apoyo, con menos consenso que una norma.

Tipo de norma	Cómo reconocerla	Consecuencia
De requisitos	El título dice <i>Requirements</i> ; usa «debe» (<i>shall</i>)	Es certificable: un organismo acreditado audita su cumplimiento
De directrices	El título dice <i>Guidelines</i> o <i>Guidance</i> ; usa «debería» (<i>should</i>)	Orienta cómo hacer algo; no se certifica

Siglas

Sigla	Significado literal	En español
ASVS	Application Security Verification Standard	Estándar de verificación de seguridad de aplicaciones
ATT&CK	Adversarial Tactics, Techniques, and Common Knowledge	Tácticas, técnicas y conocimiento común de adversarios
BIA	Business Impact Analysis	Análisis de impacto al negocio
CFReDS	Computer Forensic Reference Data Sets	Conjuntos de datos de referencia para forense informática
CIS	Center for Internet Security	Centro para la Seguridad en Internet
CISA	Cybersecurity and Infrastructure Security Agency	Agencia de Ciberseguridad y Seguridad de Infraestructura, de EE. UU.
CSF	Cybersecurity Framework	Marco de ciberseguridad
CVSS	Common Vulnerability Scoring System	Sistema común de puntuación de vulnerabilidades
DEFR	Digital Evidence First Responder	Primer respondiente de evidencia digital
DNS	Domain Name System	Sistema de nombres de dominio
FIRST	Forum of Incident Response and Security Teams	Foro de equipos de respuesta a incidentes y de seguridad
HTTP	Hypertext Transfer Protocol	Protocolo de transferencia de hipertexto
IDS	Intrusion Detection System	Sistema de detección de intrusos
IEC	International Electrotechnical Commission	Comisión Electrotécnica Internacional
IETF	Internet Engineering Task Force	Grupo de trabajo de ingeniería de Internet
IG	Implementation Group	Grupo de implementación de los CIS Controls
INN	Instituto Nacional de Normalización	Sigla en español; organismo de normalización de Chile
IPS	Intrusion Prevention System	Sistema de prevención de intrusos
IR	Interagency or Internal Report	Informe interinstitucional o interno del NIST

Sigla	Significado literal	En español
ISO	International Organization for Standardization	Organización Internacional de Normalización. No es una sigla literal: viene del griego <i>í</i> sos, «igual», para que el nombre sea el mismo en todos los idiomas
KEV	Known Exploited Vulnerabilities	Vulnerabilidades explotadas conocidas
MITRE	No es una sigla	Nombre propio de The MITRE Corporation, organización sin fines de lucro de EE. UU.
MTPD	Maximum Tolerable Period of Disruption	Período máximo tolerable de interrupción
NCh	Norma Chilena	Sigla en español de las normas publicadas por el INN
NIST	National Institute of Standards and Technology	Instituto Nacional de Estándares y Tecnología, de EE. UU.
OWASP	Open Worldwide Application Security Project	Proyecto abierto mundial de seguridad de aplicaciones; hasta 2023, <i>Open Web Application Security Project</i>
RFC	Request for Comments	Solicitud de comentarios
RPO	Recovery Point Objective	Objetivo de punto de recuperación
RTO	Recovery Time Objective	Objetivo de tiempo de recuperación
SGSI	Sistema de Gestión de Seguridad de la Información	Sigla en español de ISMS, <i>Information Security Management System</i>
SNI	Server Name Indication	Indicación del nombre del servidor
SP	Special Publication	Publicación especial del NIST
SSDF	Secure Software Development Framework	Marco de desarrollo seguro de software
SWGDE	Scientific Working Group on Digital Evidence	Grupo de trabajo científico sobre evidencia digital
TIC	Tecnologías de la Información y la Comunicación	Sigla en español de ICT, <i>Information and Communication Technology</i>
TLS	Transport Layer Security	Seguridad de la capa de transporte
TS	Technical Specification	Especificación técnica, como en ISO/TS
WSTG	Web Security Testing Guide	Guía de pruebas de seguridad web

Qué documento busco

Necesito...	Norma
Vocabulario común de la serie 27000	ISO/IEC 27000
Certificar un sistema de gestión de seguridad de la información (SGSI)	ISO/IEC 27001
Detalle de cómo implementar un control	ISO/IEC 27002
Gestionar riesgos de seguridad de la información	ISO/IEC 27005
Gestionar cualquier tipo de riesgo	ISO 31000
Gestionar la privacidad de datos personales	ISO/IEC 27701
Auditar un sistema de gestión	ISO 19011 e ISO/IEC 27007
Mantener la operación durante una interrupción	ISO 22301
Hacer un análisis de impacto al negocio (BIA)	ISO/TS 22317
Gestionar un incidente de seguridad	Serie ISO/IEC 27035
Identificar, recolectar, adquirir y preservar evidencia digital	ISO/IEC 27037
Validar que un método o herramienta forense es adecuado	ISO/IEC 27041
Analizar e interpretar evidencia digital	ISO/IEC 27042
Ordenar el proceso completo de una investigación	ISO/IEC 27043
Decidir qué evidencia adquirir primero según su volatilidad	RFC 3227
Integrar técnicas forenses en la respuesta a incidentes	NIST SP 800-86
Evaluar riesgos paso a paso	NIST SP 800-30

Necesito...	Norma
Comunicar el estado de ciberseguridad con perfiles	NIST CSF 2.0
Priorizar controles básicos	CIS Controls v8.1
Nombrar las técnicas de un atacante	MITRE ATT&CK
Medir la severidad técnica de una vulnerabilidad	CVSS

Normas ISO de gestión de la seguridad y del riesgo

Norma	Título abreviado	Tipo	Idea clave	Lecciones
ISO/IEC 27000:2018	Visión general y vocabulario	Vocabulario	Define los términos de toda la serie 27000; se descarga gratis	INF44 L07 a L11
ISO/IEC 27001:2022	SGSI: requisitos	Requisitos	Cláusulas 4 a 10 y Anexo A con 93 controles en cuatro temas: organizacionales (37), de personas (8), físicos (14) y tecnológicos (34)	INF44 L08, L11
ISO/IEC 27002:2022	Controles de seguridad de la información	Directrices	Explica propósito y guía de implementación de los mismos 93 controles	INF44 L03 a L05, L11
ISO/IEC 27005:2022	Gestión de riesgos de seguridad de la información	Directrices	Desarrolla el riesgo que exige 27001; identifica riesgos por eventos o por activos	INF44 L07 a L10
ISO 31000:2018	Gestión del riesgo	Directrices	Principios, marco y proceso aplicables a cualquier riesgo	INF44 L07, L08
ISO 19011:2026	Auditoría de sistemas de gestión	Directrices	Principios del auditor, programa de auditoría y evidencia; incluye auditoría remota	INF44 L11
ISO/IEC 27007:2020	Auditoría del SGSI	Directrices	Aplica 19011 a un sistema de gestión basado en 27001	INF44 L11
ISO/IEC 27701:2025	Sistema de gestión de la información de privacidad	Requisitos	Desde 2025 es certificable por sí sola; aplica la lógica de 27001 al tratamiento de datos personales	INF44 L07 a L12, caso con Ley 21.719

Normas ISO de continuidad e incidentes

Norma	Título abreviado	Tipo	Idea clave	Lecciones
ISO 22301:2019	Sistema de gestión de la continuidad del negocio	Requisitos	Exige BIA, evaluación de riesgos, estrategias, planes y ejercicios	INF44 L13, L14
ISO/TS 22317:2021	Análisis de impacto al negocio	Especificación técnica	Cómo priorizar procesos y fijar tiempos de recuperación	INF44 L14
ISO/IEC 27031:2025	Preparación de las TIC para la continuidad	Directrices	Cómo la tecnología sostiene la continuidad del negocio	INF44 L13
ISO/IEC 27035-1:2023 y 27035-2:2023	Gestión de incidentes de seguridad	Directrices	Cinco fases: planificar y preparar; detectar e informar; evaluar y decidir; responder; aprender	INF44 L15; INF43 L12 a L15

Normas ISO de evidencia digital

Norma	Título abreviado	Tipo	Idea clave	Lecciones
ISO/IEC 27037:2012	Identificación, recolección, adquisición y preservación de evidencia digital	Directrices	Manejo inicial de la evidencia y cadena de custodia	INF43 L02, L04, L06, L10
ISO/IEC 27041:2015	Idoneidad de los métodos de investigación	Directrices	Validar y verificar que un método o herramienta sirve para su propósito	INF43 L03, L12
ISO/IEC 27042:2015	Análisis e interpretación de evidencia digital	Directrices	Análisis, interpretación, informe y competencia del analista	INF43 L06, L07, L11, L12
ISO/IEC 27043:2015	Principios y procesos de investigación de incidentes	Directrices	Modelo del proceso completo, de la preparación al cierre	INF43 L02, L12

Norma	Título abreviado	Tipo	Idea clave	Lecciones
ISO/IEC 17025:2017	Competencia de laboratorios de ensayo	Requisitos	Base para acreditar un laboratorio, incluido uno forense	INF43 L03

Las normas 27037, 27041, 27042 y 27043 se leen como un conjunto: 27043 ordena el proceso completo, 27037 cubre el manejo inicial de la evidencia, 27042 su análisis y 27041 la validez de los métodos usados.

Publicaciones del NIST

Gratuitas. **SP** es una guía (*Special Publication*); **IR** un informe (*Interagency Report*); **Rev.** indica la revisión.

Documento	Título abreviado	Idea clave	Lecciones
NIST CSF 2.0 (2024)	Marco de ciberseguridad	Seis funciones (GOVERN, IDENTIFY, PROTECT, DETECT, RESPOND, RECOVER), perfiles y <i>Tiers</i>	INF44 L03, L07 a L09, L11, L13
SP 800-30 Rev. 1	Evaluación de riesgos	Preparar, realizar, comunicar y mantener la evaluación	INF44 L07 a L10, L17
SP 800-39	Gestión del riesgo de seguridad	Enmarcar, evaluar, responder y supervisar	INF44 L08
IR 8286 Rev. 1 e IR 8286A Rev. 1	Riesgo de ciberseguridad en la gestión del riesgo empresarial	Apetito, tolerancia y registro de riesgos	INF44 L07, L08, L10
IR 8286D	BIA para priorizar riesgos	Usa el análisis de impacto al negocio para decidir la respuesta	INF44 L14
SP 800-53 Rev. 5 y SP 800-53A Rev. 5	Catálogo de controles y su evaluación	Controles de seguridad y privacidad, y cómo comprobarlos	INF44 L03, L11, L12
SP 800-41 Rev. 1	Firewalls y política de firewall	Denegación por defecto y reglas documentadas	INF44 L04, L05
SP 800-94	Sistemas de detección y prevención de intrusos	Tipos de IDS/IPS, ubicación de sensores y ajuste	INF44 L05, L06
SP 800-40 Rev. 4	Gestión de parches	Planificar y priorizar actualizaciones	INF44 L10, L15, L17
SP 800-218 (SSDF)	Desarrollo seguro de software	Prácticas para producir software seguro	INF44 L03, L11, L18
SP 800-34 Rev. 1	Planes de contingencia	BIA, estrategias de recuperación y pruebas	INF44 L13, L14
SP 800-84	Pruebas, capacitación y ejercicios	Diseño de ejercicios de mesa y simulacros	INF44 L15, L16
SP 800-61 Rev. 3 (2025)	Respuesta a incidentes	Respuesta a incidentes organizada con las funciones de CSF 2.0	INF44 L01, L15, L16; INF43 L01, L02, L12
SP 800-86	Técnicas forenses en respuesta a incidentes	Recolección, examen, análisis e informe	INF43 L01, L02, L04, L05, L07, L08, L11, L12, L17, L18
SP 800-92	Gestión de registros (<i>logs</i>)	Generar, conservar y analizar registros	INF43 L08, L09
SP 800-83 Rev. 1	Incidentes de malware	Prevención y manejo de malware en equipos	INF43 L13
SP 800-101 Rev. 1	Forense de dispositivos móviles	Aislamiento, adquisición y validación en móviles	INF43 L10
SP 800-201	Arquitectura forense para cloud	Desafíos forenses propios de la nube	INF43 L10
NIST CFReDS	Conjuntos de datos forenses de referencia	Imágenes y capturas públicas para practicar y validar herramientas	INF43 L05, L08, L16, L18

RFC

Documentos técnicos de Internet publicados por la IETF. Gratuitos en <https://www.rfc-editor.org>.

RFC	Tema	Idea clave	Lecciones
RFC 3227	Recolección y archivo de evidencia	Orden de volatilidad: se adquiere primero lo más volátil	INF43 L06

RFC	Tema	Idea clave	Lecciones
RFC 1035	DNS	Estructura de consultas y respuestas	INF43 L08
RFC 9110	Semántica de HTTP	Métodos, códigos de estado y cabeceras	INF43 L08
RFC 8446	TLS 1.3	<i>Handshake</i> y negociación del cifrado	INF43 L08
RFC 6066	Extensiones de TLS	Define el SNI	INF43 L08
RFC 5737	Direcciones IPv4 para documentación	192.0.2.0/24 , 198.51.100.0/24 y 203.0.113.0/24 no se usan en Internet	INF43 L08
RFC 2606	Dominios reservados	.invalid , .example y .test para ejemplos	INF43 L08

Marcos y catálogos de la industria

Documento	Emisor	Idea clave	Lecciones
Cyber Kill Chain	Lockheed Martin	Siete fases de un ataque, desde el reconocimiento hasta las acciones sobre el objetivo	INF44 L01, L02, L06
MITRE ATT&CK	MITRE	Catálogo de tácticas y técnicas observadas en ataques reales	INF44 L01, L02, L09; INF43 L13 a L15, L17
CIS Controls v8.1	Center for Internet Security	18 controles priorizados en tres grupos de implementación (IG1 a IG3)	INF44 L02, L03, L06, L12
OWASP Top 10:2025	OWASP	Riesgos más frecuentes en aplicaciones web	INF44 L02, L18
OWASP ASVS 5.0	OWASP	Requisitos verificables de seguridad para aplicaciones	INF44 L03, L11, L18
OWASP WSTG	OWASP	Guía para probar la seguridad de aplicaciones web	INF44 L18; INF43 L15
CVSS v3.1	FIRST	Puntaje de 0 a 10 de la severidad técnica de una vulnerabilidad; no es riesgo	INF44 L08
Catálogo KEV	CISA	Vulnerabilidades con explotación conocida; ayuda a priorizar parches	INF44 L09
Guías SWGDE	Scientific Working Group on Digital Evidence	Buenas prácticas de adquisición y análisis por tipo de evidencia	INF43 L03, L04, L06, L10, L12, L15, L17

Normativa chilena citada

Norma	Tema	Lecciones
Ley 19.628	Protección de la vida privada y datos personales	INF44 L07, L08; INF43 L06
Ley 21.096	Protección de datos personales como derecho constitucional	INF44 L07, L08
Ley 21.719	Nueva ley de protección de datos personales, vigente desde el 1 de diciembre de 2026	INF44 L07, L08; INF43 L06
Ley 21.663	Ley Marco de Ciberseguridad	INF44 L07, L08

Conceptos que se preguntan

Concepto	Norma	Definición breve
Principios del manejo de evidencia	27037	Auditabilidad, repetibilidad, reproducibilidad y justificabilidad
Repetibilidad	27037, 27042	Mismo método, mismo entorno y misma persona obtienen el mismo resultado

Concepto	Norma	Definición breve
Reproducibilidad	27037, 27042	Mismo método, otro entorno u otra persona obtienen el mismo resultado
DEFR	27037	Primer respondiente de evidencia digital: quien identifica, recolecta y adquiere
Declaración de aplicabilidad	27001	Documento que indica qué controles del Anexo A se aplican y por qué
Opciones de tratamiento	27005	Evitar, modificar, compartir o retener el riesgo
Riesgo residual	27005, 31000	Riesgo que queda después del tratamiento y que alguien con autoridad acepta
RTO	22301	Tiempo máximo para reanudar una actividad después de una interrupción
RPO	22301	Punto hasta el que se debe poder recuperar la información
MTPD	22301	Período máximo que la organización tolera una interrupción

Equivalencias con NIST

Equivalente significa que ambos documentos tratan el **mismo tema**, no que sean intercambiables. Difieren en alcance, estructura y nivel de detalle, y en su acceso: las normas ISO son de pago, y algunas se certifican, mientras que las publicaciones del NIST son guías gratuitas. Sirve para encontrar el documento correspondiente cuando un informe o una organización usa el otro marco.

Tema	Norma ISO	Documento NIST
Evaluación del riesgo	ISO/IEC 27005	NIST SP 800-30
Resultados de ciberseguridad y perfiles	ISO/IEC 27001 y 27002	NIST CSF 2.0
Respuesta a incidentes	ISO/IEC 27035	NIST SP 800-61
Continuidad	ISO 22301	NIST SP 800-34
Técnicas forenses en respuesta a incidentes	ISO/IEC 27037 y 27042	NIST SP 800-86

Acceso a los documentos

- Las normas ISO son de pago. La plataforma **ISO Online Browsing Platform** (<https://www.iso.org/obp>) muestra gratis el alcance, los términos y la tabla de contenidos.
- ISO/IEC 27000** es una de las normas de libre acceso: se obtiene sin costo en la tienda de ISO (<https://www.iso.org/store.html>).
- En Chile, el Instituto Nacional de Normalización (INN) publica algunas como normas chilenas NCh-ISO; comprueba cuál edición adoptó.
- Las publicaciones del NIST son gratuitas: <https://csrc.nist.gov/publications>.
- MITRE ATT&CK, OWASP y CISA KEV son de libre acceso; los CIS Controls se descargan gratis con registro.